

# Politica di Sicurezza delle Informazioni

Versione: 1.0

Owner: Chief Information Security Officer

Approvata da: Consiglio di Amministrazione

Ciclo di revisione: Annuale

Data di entrata in vigore: 06/08/2026

## Purpose

Lo scopo di questa policy è definire i principi generali di sicurezza delle informazioni adottati da Finaxa Financial Services per proteggere i dati sensibili, finanziari, personali, dei servizi digitali e garantire la fiducia dei clienti e stakeholder, ridurre il rischio di incidenti cyber e supportare la compliance per garantire la confidenza, l'integrità e la disponibilità.

## Scope

La presente policy si applica a tutti i dipendenti, collaboratori esterni, consulenti, contractor, fornitori terzi e utenti autorizzati che accedono ai sistemi, ai dati o ai servizi di Finaxa Financial Services.

Il perimetro include i sistemi on-premise, gli ambienti cloud AWS, Microsoft 365, le applicazioni SaaS, gli endpoint aziendali, le reti interne, i sistemi di pagamento, i database clienti e tutti gli strumenti utilizzati per trattare informazioni aziendali o dei clienti.

La policy si applica a tutti i dati trattati dall'organizzazione, inclusi dati personali dei clienti, dati finanziari, dati di pagamento, credenziali utente, dati dei dipendenti, documentazione interna riservata e audit logs.

## Policy statements

Finaxa Financial Services deve mantenere un ISMS allineato a ISO 27001:2022.

I rischi di cybersecurity devono essere identificati, valutati e trattati secondo un processo documentale di risk management.

L'accesso ai dati e ai sistemi deve essere concesso solo in base al principio di least privilege in base alle necessità lavorative autorizzate.

I dati devono essere protetti in base al loro livello di sensibilità e valore per il business.

Tutti gli utenti hanno la massima responsabilità della protezione delle informazioni, del impatto che posso avere se non autorizzati e segnalare tempestivamente eventi sospetti o incidenti.

## Roles and Responsibilities

I ruoli di responsabilità devono essere chiari in modo che noi reparto possa comunicare e implementare ognuno le misure di sicurezza adeguate.

Il board of Director ha il compito importante di approvare le misure prese in lettura di governance e risk appetite.

Il CISO è responsabile di gestire il programma di sicurezza definito e che deve implementare riportandosi sempre al board.

IT security team deve eseguire operativamente in modo da implementare tutte le direttive, monitorare, configurare e aggiornare in base a tutti gli aggiornamenti dati.

Staff e dipendenti devono diventare consapevoli del rischio e applicare le regole date.

Terze parti devono rispettare tutti gli obblighi contrattuali in vigore nel programma di sicurezza.

# Compliance and Enforcement

Finaxa opera in un settore regolamentato e deve garantire che la gestione della sicurezza delle informazioni sia coerente con i requisiti legali, regolamentari, contrattuali e interni applicabili. La presente policy supporta il rispetto del **GDPR**, applicabile al trattamento dei dati personali di clienti, dipendenti e altri interessati nell'Unione Europea; del **UK GDPR** e del **Data Protection Act 2018**, applicabili alle attività svolte nel Regno Unito; del **PCI DSS**, applicabile alla protezione dei dati di pagamento e delle transazioni con carta; e del **Digital Operational Resilience Act**, o **DORA**, rilevante per la resilienza operativa digitale e la gestione del rischio ICT nel settore finanziario europeo.

Eventuali requisiti **SOX** saranno considerati solo qualora Finaxa sia soggetta a obblighi di reporting finanziario collegati a una società quotata negli Stati Uniti o a specifici requisiti contrattuali. Il **GLBA** non rientra nel perimetro principale dell'organizzazione, salvo futura estensione operativa verso il mercato statunitense o verso soggetti regolati da tale normativa.

Il rispetto della presente policy è obbligatorio per tutti i dipendenti, collaboratori esterni, consulenti, contractor, fornitori terzi e utenti autorizzati che accedono ai sistemi, ai dati o ai servizi di Finaxa. Qualsiasi violazione della policy può comportare misure proporzionate alla gravità dell'evento, incluse azioni disciplinari, revoca o limitazione degli accessi, escalation al management, investigazioni interne e, per le terze parti, azioni previste dai contratti, dagli SLA o dagli accordi di trattamento dei dati.

Eventuali eccezioni alla presente policy devono essere documentate, motivate da una necessità aziendale, valutate in termini di rischio e approvate dal **Chief Information Security Officer** o da un'autorità equivalente designata. Le eccezioni approvate devono essere riesaminate periodicamente per verificare che rimangano giustificate e coerenti con il livello di rischio accettabile dell'organizzazione.

## Related Documents

La presente **Politica di Sicurezza delle Informazioni** costituisce il documento principale della policy suite di Finaxa e definisce i principi generali di governance, responsabilità e protezione delle informazioni aziendali. I requisiti più specifici e operativi sono descritti in policy e procedure subordinate, che devono essere coerenti con i principi stabiliti in questo documento.

L' **Access Control Policy** definisce le regole per la gestione degli accessi ai sistemi, inclusi il principio del **least privilege**, l'utilizzo della **MFA**, la gestione degli account privilegiati e il processo di creazione, modifica e revoca degli accessi. La **Data Classification and Handling Policy** stabilisce come le informazioni devono essere classificate, trattate, conservate, condivise e protette in base al loro livello di sensibilità. La **Incident Response Policy** descrive le responsabilità e le modalità di segnalazione, escalation, gestione e documentazione degli incidenti di sicurezza, inclusi eventuali **data breach**.

Ulteriori documenti collegati possono includere la **Third-Party Risk Management Policy**, la **Acceptable Use Policy** e la **Business Continuity and Disaster Recovery Policy**, in base all'evoluzione del programma di sicurezza e compliance dell'organizzazione. Tutti i documenti subordinati devono essere mantenuti aggiornati, approvati dagli owner competenti e revisionati periodicamente per garantire coerenza con la presente policy, con il profilo di rischio dell'organizzazione e con i requisiti normativi applicabili.

## Review and revision

La presente **Politica di Sicurezza delle Informazioni** sarà revisionata almeno una volta all'anno per garantire che rimanga aggiornata, efficace e coerente con il profilo di rischio, gli obiettivi aziendali e i requisiti normativi applicabili a Finaxa.

Il **Chief Information Security Officer** è responsabile del coordinamento del processo di revisione, con il supporto delle funzioni IT, Risk Management, Compliance, Legal e dei system owner interessati. La revisione dovrà verificare che lo scope della policy, le responsabilità, i riferimenti normativi e i principi di sicurezza siano ancora adeguati rispetto all'ambiente operativo dell'organizzazione.

La policy potrà essere revisionata anche prima della scadenza annuale in caso di incidenti di sicurezza significativi, data breach, audit finding rilevanti, modifiche normative, cambiamenti sostanziali nell'ambiente IT, introduzione di nuovi fornitori critici, fusioni, acquisizioni o modifiche rilevanti al modello operativo dell'organizzazione.

Le modifiche minori potranno essere approvate dal CISO, mentre le modifiche significative che impattano governance, responsabilità, compliance o risk appetite dovranno essere sottoposte al **Board of Directors** o a un comitato di governance designato.

Ogni aggiornamento dovrà essere documentato tramite controllo di versione, data di revisione, descrizione delle modifiche e approvazione dell'owner competente. La versione aggiornata della policy dovrà essere comunicata agli utenti interessati e resa disponibile nei canali documentali ufficiali dell'organizzazione.